

Case 3 In-Class Assignment

Business Resilience

By: Tim Loudon, Melvin Viado, Daniel Lindo

A dark blue diagonal gradient bar that starts from the bottom left corner and extends towards the top right corner, covering the lower half of the slide.

Case

“A user in the HR department receives an e-mail with an attachment from someone claiming to be a new hire. The e-mail was from a sender not in the company address book. The subject of the e-mail was “New Hire Forms”. The HR employee opens the e-mail and immediately all of their files become encrypted. They phone the service desk asking for help.”

4 Phases

Preparation

Detection and Analysis

Containment, Eradication, Recovery

Post Incident Activity

Phase 1 – Preparation

- Routine quarterly staff training sessions should be implemented so that staff at all company levels understand to be wary of emails outside the company address book, especially with clicking on unvalidated attachments. Naturally, all emails outside the company should be treated as suspicious.
- Antivirus would be installed on all staff computers that are industry standard (though this does not account for zero day exploits)
- In the event that an email is received from an unknown address outside the company, it should be immediately flagged, not matter how innocent it appears to be

Phase 1 –Preparation – Part 2

Our IT department should have experience:

- SOC analysts
- and all emails originating outside the company should be redirected from staff to be analyzed for safety and flagged as potentially dangerous/compromising to company resources

Before this event occurs, steps should have been taken to incorporate:

- A list of email addresses to deny, along with firewall rules for the email system.
- file extensions within the email should be blocked
- blocking known IP Addresses, domains and URLs that are known to be malicious.

Phase 2 – Detection and Analysis

Once the ransomware infection has been detected and reported, containment steps need to be taken to ensure that the malicious actor does not gain more access to the company's systems and protect any forensic evidence for an investigation

These steps include:

- Enacting containment procedures according to the IR plan
- Reviewing system logs
- Reviewing EDR/SIEM reports

Phase 2 – Detection and Analysis

SOC team should be sent samples of the malware for analysis and to try and determine the extent of infection.

Logs should also be reviewed for this purpose to investigate what scripts were used for the encryption, if it can be reversed, and clues to the attacker's identity

Other devices on the network should also be under higher levels of scrutiny to detect any lateral movement from the attacker

Phase 3 – Containment, Eradication, Recovery

Decision Criteria

- Confirm encryption
- Malicious email traits
- Change in user file access

Phase 3 – Containment, Eradication, Recovery

Containment

Initiated once attack is confirmed to stop further damage and limit attack spread

- Remove device from network
- Isolate the compromised account
- Revoke active session of the account
- Force password reset
- Block where email is sent from
- Notify Security Team

Phase 3 – Containment, Eradication, Recovery

Eradication

- Delete or remove malicious emails
- Remove unauthorized inbox or forwarding rules
- Scan systems
- Close entry points
- Patch weaknesses

Phase 3 – Containment, Eradication, Recovery

Recovery

- Validate accounts and email flow
- Restore systems
- Further monitoring
- Inform about password resets
- Inform about post-attack instructions

Phase 4 – Post Incident Activity

- After the incident has been resolved and operations have resumed as normal, a timeline of events for the incident should be compiled and submitted to members of the IR team for review and to come up with any further actions that need to be taken
- If an EDR was installed on the employee's computer, all forensic data from the time of the ransomware attack should be compiled and added to the report
- Members of the IR team including anyone that was part of handling the incident should meet together to discuss the steps taken and what can be done to make similar incidents be handled more efficiently
- New employee training should be devised to mitigate any future incidents both ransomware related and otherwise

Specific Considerations



Specific Considerations

- The employee calling the help desk and the discovery of the encrypted files on their computer (ransomware) is what triggered the event
- Training that should be given to ensure that when any suspicious event occurs on the computers, they should call the help desk for assistance. It is then up to the help desk employees to be trained to recognize what is going on and contact the IRT if necessary
- The process to activate the IRT starts with the help desk employee reaching out to their manager (who should be a member of the team) saying that they believe there has been an incident. The manager then collects all the information to determine if an incident has truly occurred and informs the rest of the IRT of the scenario. The steps of the IR plan are then followed until the incident has been resolved

Specific Consideration – Part 2

- Procedures taken during the IR team's investigation should follow their playbook and follow detection and analysis, containment, eradication, recovery, and reviewing what happened to improve the IR plan for future incidents
- Evidence is protected and stored securely by maintaining a record of what occurred over the course of the incident including a timeline of events, system logs, reports generated from EDR/SIEM applications, a record of steps taken to contain and eradicate the malware, and recover from the incident
- IRT members are appointed based on their role in the company including members from senior management, SOC team members, help desk, system administrators, legal teams, and HR staff
- The IR team falls under the information security category

Common Incidents and Appropriate Responses

- What triggered the event?
 - Triggered via a malicious email originating outside the company email address book
- How is it ensured that the users and the service desk employees know when to contact the IRT? (ex. what training is given?)
 - Staff should be trained to treat all emails outside the company as suspicious and report it to the IT department for analysis
- What is the process to activate the IRT?
 - Two primary causes, notification of the incident by staff, and robust system security systems (Antivirus, SIEM logs, etc)

Common Incidents and Appropriate Responses – Part 2

- What procedures are followed during the IRT investigation?

- How is evidence protected and stored?

- How are the IRT members appointed and trained?

- What category does the IRT team fall under?

- Analysis of the email sender, source ip, attachments, etc (within a sandbox environment)
- Evidence should be routinely backed up on an on and off site server or series of servers for analysis. Drives on these servers should have a robust raid configuration along with encryption. Air gapped computers should also be utilized.
- IRT members are promoted internally, and hired externally. Optimally we want experienced soc analysts and IT members with experience in cybersecurity
- The IRT team will fall under our IT security, specifically our cybersecurity team that handles all situations relating to worst case incidents